

BSc (Hons) in Information Technology Specializing Data Science

Research Project - IT4010

Ethical Analysis Report

Group ID: 25-26J-129

Project Title: Modular Multi-Agent Document AI Platform: Adaptive Policy Routing and Explainable Document Intelligence

	Identification and Analysis
Data Privacy Concerns	The platform processes sensitive documents including clinical summaries, bank statements, insurance claims, and invoices containing Personally Identifiable Information (PII). Key data privacy concerns include: (1) PII exposure during document processing, since OCR and LLM extraction stages handle raw document text that may contain patient names, medical licence numbers, credit card numbers, IBAN codes, and national registration numbers. The Guardrail Ensemble addresses this through a dedicated PII Leakage Detection layer using Microsoft Presidio with per-document-type allowlists and blocklists. (2) Informed consent: documents submitted to the platform are assumed to be provided by authorised users via the API Gateway; however, individuals whose data appears within documents (e.g., patients in clinical summaries) have not directly consented to AI processing. (3) Data minimization: the system stores raw outcome logs (mtm_outcomes) and audit trails (guardrail_audit_log) persistently in PostgreSQL, raising concerns about retaining more personal data than is strictly necessary. (4) Right to erasure: the current schema provides no mechanism for removing personal data associated with a specific individual from the audit or feedback tables. Example from this project: The PII Leakage Detection layer uses Microsoft Presidio to flag credit card numbers, IBAN codes, and social security numbers in all document contexts. Clinical summaries are granted an allowlist for patient names and dates, but no document type permits financial identifiers. The system does not store raw document images or full OCR text outside of the ArtifactStore, which is accessible only via the internal Docker network. Future work should add a data retention policy and a GDPR-compliant erasure endpoint.
Data Security	

BSc (Hons) in Information Technology Specializing Data Science

Research Project - IT4010

Ethical Analysis Report

	All inter-service communication is confined to an isolated internal Docker bridge network with no direct internet exposure. The API Gateway enforces JWT authentication (HS256, 24-hour access tokens, 7-day rotating refresh tokens with Redis-based blacklisting) and rate limiting at 200 requests per minute per IP. Passwords are stored using bcrypt hashing. The PostgreSQL and Redis instances are connected only to the internal network. Model artefacts (BART, SentenceTransformer, Presidio) are downloaded from HuggingFace and cached locally, reducing ongoing external network dependency during inference.
Bias and Fairness	Thompson Sampling posteriors in the AHMN are seeded from 21 LTM entries across 11 policies, a relatively small set that may encode biases favouring document types well-represented in the seed data (e.g., invoices) over underrepresented types (e.g., Sri Lankan-format clinical summaries). The Guardrail Domain Rules layer applies tax plausibility thresholds based on the Sri Lanka VAT rate of 18%, which may produce false positives for documents originating from other jurisdictions. The Presidio PII model is trained on English-language data and has reduced accuracy for Sri Lankan names, addresses, and NIC numbers, potentially leading to unequal privacy protection across demographic groups.
Transparency and Accountability	The XAI-HITL service provides two complementary explainability mechanisms: BART cross-attention visualisation, which highlights the source text passages that most influenced each generated answer, and LIME word importance scores, which quantify each context word's contribution to the answer probability. The HITL feedback loop allows human reviewers to mark answers as correct, incorrect, partially correct, or needing more context, with structured 1-to-5 ratings for explanation quality. All Guardrail validation decisions are persisted to the guardrail_audit_log table, providing a complete and queryable audit trail. The ProvenanceRecorder logs every agent's inputs, outputs, and configuration parameters, enabling post-hoc analysis of any pipeline decision.
Impact on Stakeholders	End users (business operators, clinicians, financial analysts) benefit from faster and more reliable document extraction but are affected if hallucinated values pass undetected through the Guardrail Ensemble; the faithfulness threshold of 0.62 and the six-layer sequential design are intended to minimise this risk. Individuals whose personal data appears in processed documents (patients, customers) are affected by PII leakage risks; the Presidio-based detection layer and document-type-specific allowlists are the primary mitigations. System administrators benefit from the deep health-check endpoint and the Docker Compose deployment but bear responsibility for maintaining JWT secret rotation and database backup. Developers and researchers benefit from the open provenance logs and experiment tracking but must ensure the AHMN seed policies are representative and unbiased before production deployment.